

CYROPAY LTD

Information Security Policy

Document Classification: Internal

Version: 1.0

Policy Owner: Chief Information Security Officer (CISO)

Approved By: Chief Executive Officer (CEO)

Effective Date: May 2026

Review Date: May 2027

Status: Approved

1. Purpose

The purpose of this Information Security Policy is to establish CyroPay Ltd's commitment to protecting the confidentiality, integrity, and availability of information assets and to define the governance framework supporting the organisation's Information Security Management System (ISMS).

This policy supports compliance with ISO/IEC 27001:2022, UK GDPR, FCA operational resilience expectations, DORA-related ICT risk management obligations, and other applicable legal, regulatory, and contractual requirements.

This policy establishes the baseline information security requirements applicable across CyroPay's operations, systems, employees, contractors, and third-party suppliers.

2. Scope

This policy applies to:

- All CyroPay employees, contractors, consultants, temporary workers, and third-party service providers.
- All systems, applications, endpoints, APIs, cloud infrastructure, and supporting technologies operating within the scope of CyroPay's ISMS.
- All information assets processed, transmitted, or stored by CyroPay.
- All remote access connections and approved remote working arrangements.
- All environments including production, development, testing, and disaster recovery environments.

This policy applies to all business functions supporting CyroPay's UK-based fintech payment services.

3. Definitions

Term	Definition
ISMS	Information Security Management System
MFA	Multi-Factor Authentication
PII	Personally Identifiable Information
CISO	Chief Information Security Officer
Risk Owner	Individual accountable for managing and mitigating a risk
Information Asset	Any data, system, service, or infrastructure component with business value
DORA	Digital Operational Resilience Act
GDPR	General Data Protection Regulation

4. Roles and Responsibilities

4.1 Board of Directors

The Board is responsible for:

- Providing strategic oversight of information security risks.
- Reviewing major ISMS risks and remediation progress.
- Supporting adequate resourcing of the ISMS.

4.2 Chief Executive Officer (CEO)

The CEO is responsible for:

- Executive accountability for information security governance.
- Ensuring organisational support for the ISMS.
- Approving major security policies.

4.3 Chief Information Security Officer (CISO)

The CISO is responsible for:

- Managing and maintaining the ISMS.
- Conducting risk assessments.

- Coordinating incident response activities.
- Monitoring compliance with security policies.
- Reporting security risks to senior management.

4.4 IT and Engineering Teams

The IT and Engineering teams are responsible for:

- Implementing security controls.
- Maintaining secure system configurations.
- Applying security patches.
- Supporting monitoring and vulnerability management.

4.5 Employees and Contractors

All personnel are responsible for:

- Complying with security policies and procedures.
 - Reporting security incidents immediately.
 - Protecting company information assets.
 - Completing mandatory security awareness training.
-

5. Policy Requirements

5.1 Information Security Governance

- CyroPay shall maintain an ISO/IEC 27001-aligned Information Security Management System.
- Information security objectives shall be reviewed annually.
- Security policies shall be reviewed at least annually or following significant business or regulatory changes.

5.2 Risk Management

- Information security risks shall be formally identified, assessed, treated, and monitored.
- Risk assessments shall use a documented likelihood and impact methodology.
- Critical and High risks shall be tracked through formal remediation plans.

5.3 Access Control

- Access to systems and information assets shall follow least-privilege principles.
- Privileged access shall be restricted to authorised personnel only.
- Shared administrative accounts shall be prohibited unless formally approved and risk assessed.

- Multi-factor authentication (MFA) shall be enforced for privileged access, VPN access, cloud administration, finance systems, and remote access services.

5.4 Asset Protection

- Information assets shall be classified according to sensitivity and business impact.
- Confidential and sensitive information shall be protected through encryption and access restrictions.
- Company-managed devices shall use approved endpoint security controls.

5.5 Vulnerability and Patch Management

- Vulnerability scanning shall be conducted regularly.
- Critical security patches shall be deployed within defined service-level agreements.
- Unsupported systems shall not be used in production environments.

5.6 Security Monitoring and Logging

- Security logs shall be retained and monitored to detect suspicious activity.
- Critical systems shall generate audit logs sufficient to support incident investigations.
- Monitoring activities shall comply with legal and privacy obligations.

5.7 Incident Management

- Security incidents shall be reported immediately to the Information Security team.
- CyroPay shall maintain a formal incident response process.
- Incidents involving personal data shall be escalated to the Data Protection Officer where appropriate.

5.8 Third-Party Security

- Third-party suppliers shall undergo security assessment prior to onboarding.
- Critical suppliers shall be subject to ongoing risk review.
- Security requirements shall be included within supplier contracts.

5.9 Secure Development

- Secure development practices shall be integrated into the software development lifecycle.
- Production data shall not be used in test environments unless appropriately masked and approved.
- Security testing shall be performed before production deployment.

5.10 Security Awareness and Training

- All personnel shall complete mandatory security awareness training annually.

- Personnel with privileged access shall receive role-specific security training.
- Phishing simulations may be conducted periodically.

5.11 Business Continuity and Resilience

- Backup and recovery processes shall be maintained for critical systems.
 - Business continuity and disaster recovery plans shall be tested periodically.
 - CyroPay shall maintain operational resilience capabilities aligned to regulatory expectations.
-

6. Compliance and Monitoring

Compliance with this policy shall be monitored through:

- Internal audits
- Risk assessments
- Vulnerability assessments
- Security monitoring activities
- Management review meetings
- Policy review processes
- Supplier assessments

Violations of this policy may result in disciplinary action, termination of access privileges, contractual action, or legal escalation where appropriate.

7. Exceptions

Any exception to this policy must:

- Be formally documented.
- Include a business justification.
- Be risk assessed.
- Be approved by the CISO.
- Include compensating controls where necessary.
- Be reviewed periodically.

Temporary exceptions must include an expiration date.

8. Related Documents

- Access Control Policy
 - Password and Authentication Policy
 - Incident Response Policy
 - Data Classification and Handling Policy
 - Supplier Security Policy
 - Acceptable Use Policy
 - Business Continuity Policy
 - Secure Development Policy
 - GDPR and Privacy Policy
 - Risk Management Procedure
 - ISMS Scope Statement
-

9. ISO/IEC 27001:2022 Annex A Mapping

Annex A Control	Description
A.5.1	Policies for information security
A.5.2	Information security roles and responsibilities
A.5.4	Management responsibilities
A.5.7	Threat intelligence
A.5.8	Information security in project management
A.5.15	Access control
A.5.19	Information security in supplier relationships
A.5.23	Information security for use of cloud services
A.5.24	Information security incident management planning and preparation
A.5.29	Information security during disruption
A.8.1	User endpoint devices
A.8.8	Management of technical vulnerabilities
A.8.15	Logging
A.8.16	Monitoring activities
A.8.25	Secure development lifecycle

10. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version